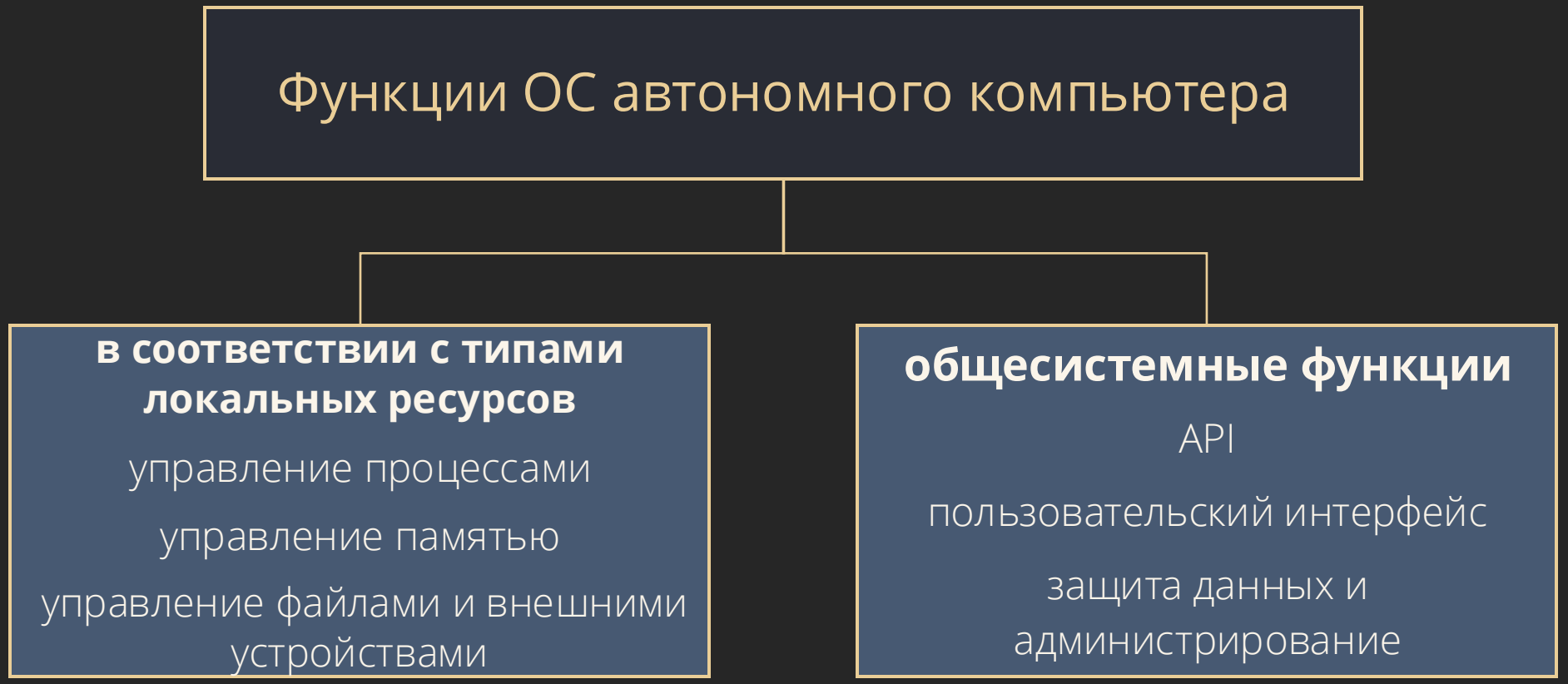
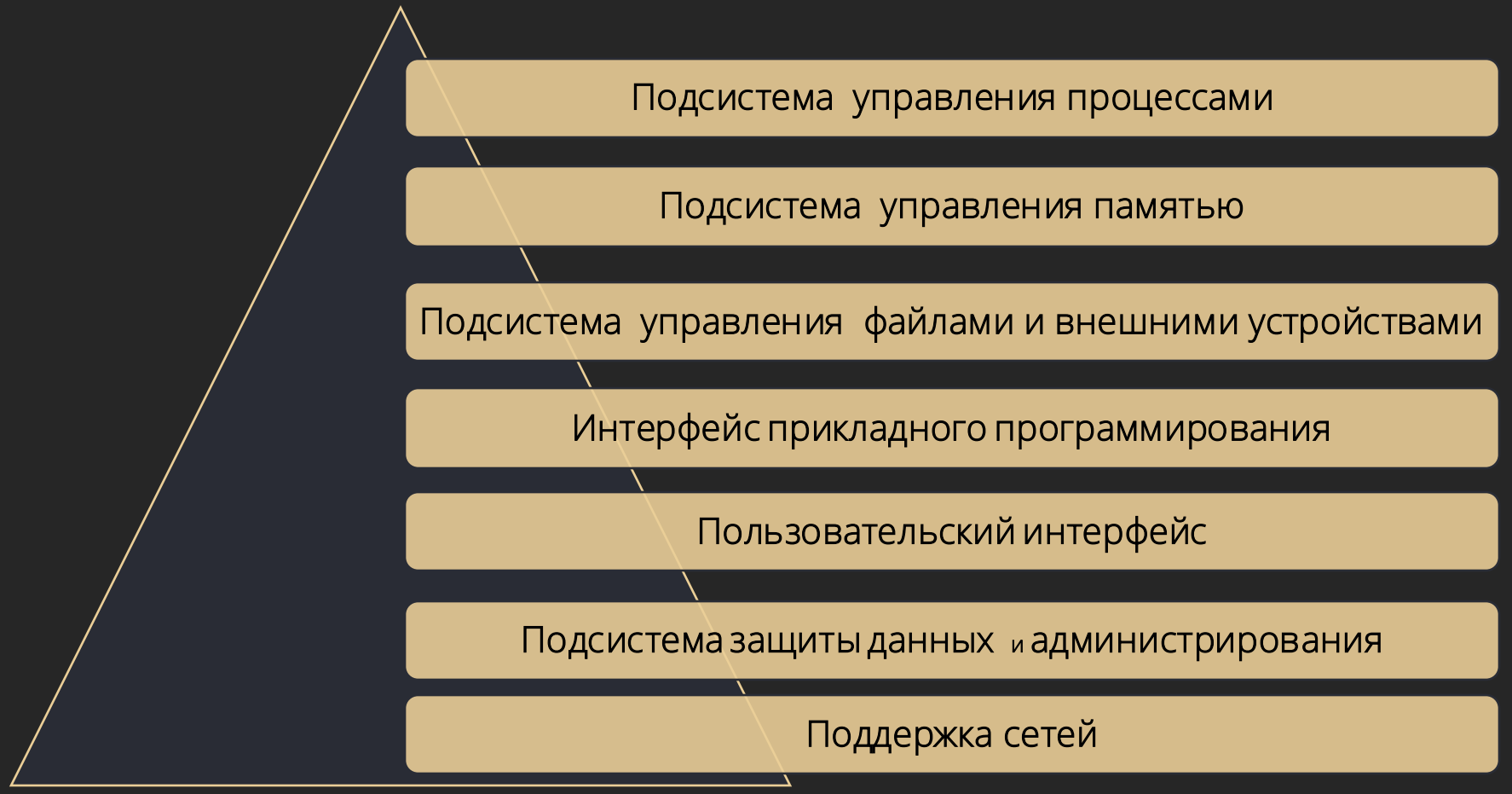
Функциональные компоненты ОС

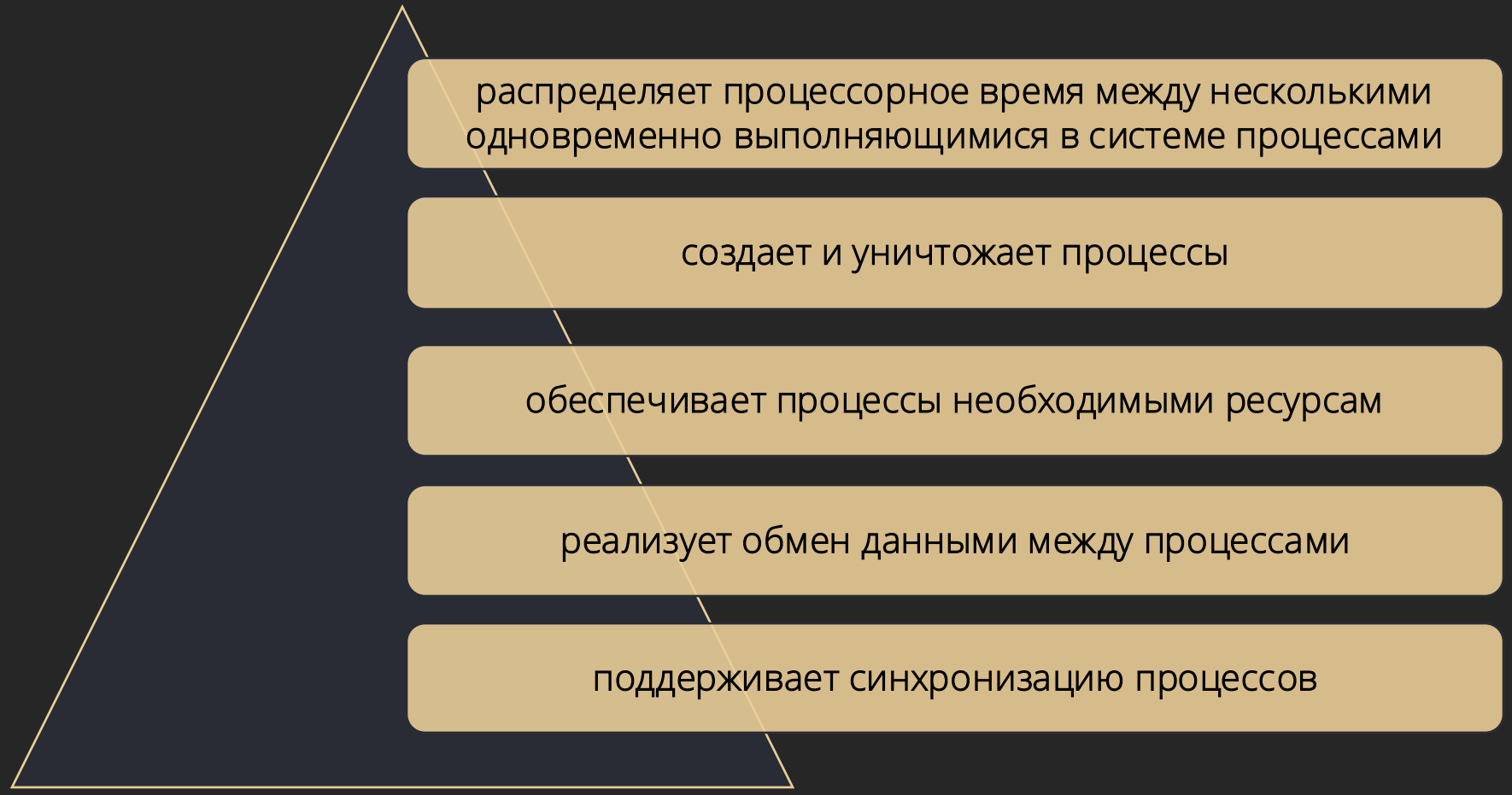
Функции операционных систем



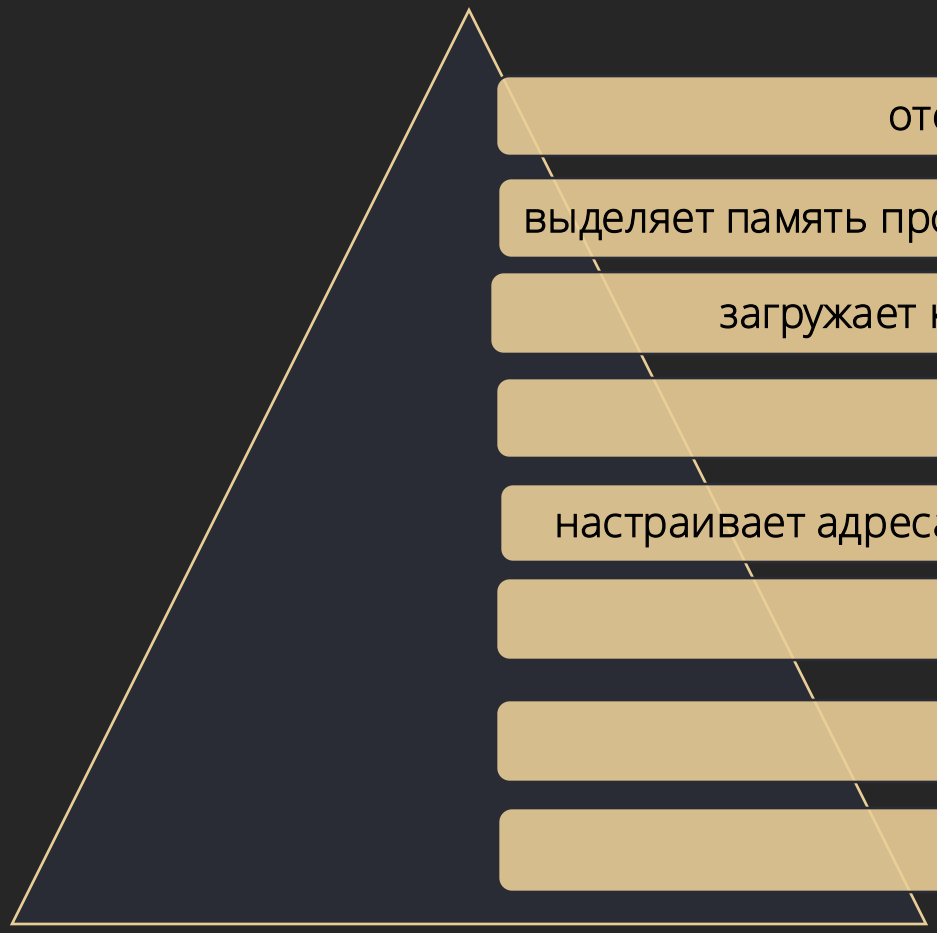
Функциональные компоненты ОС автономного компьютера



Подсистема управления процессами

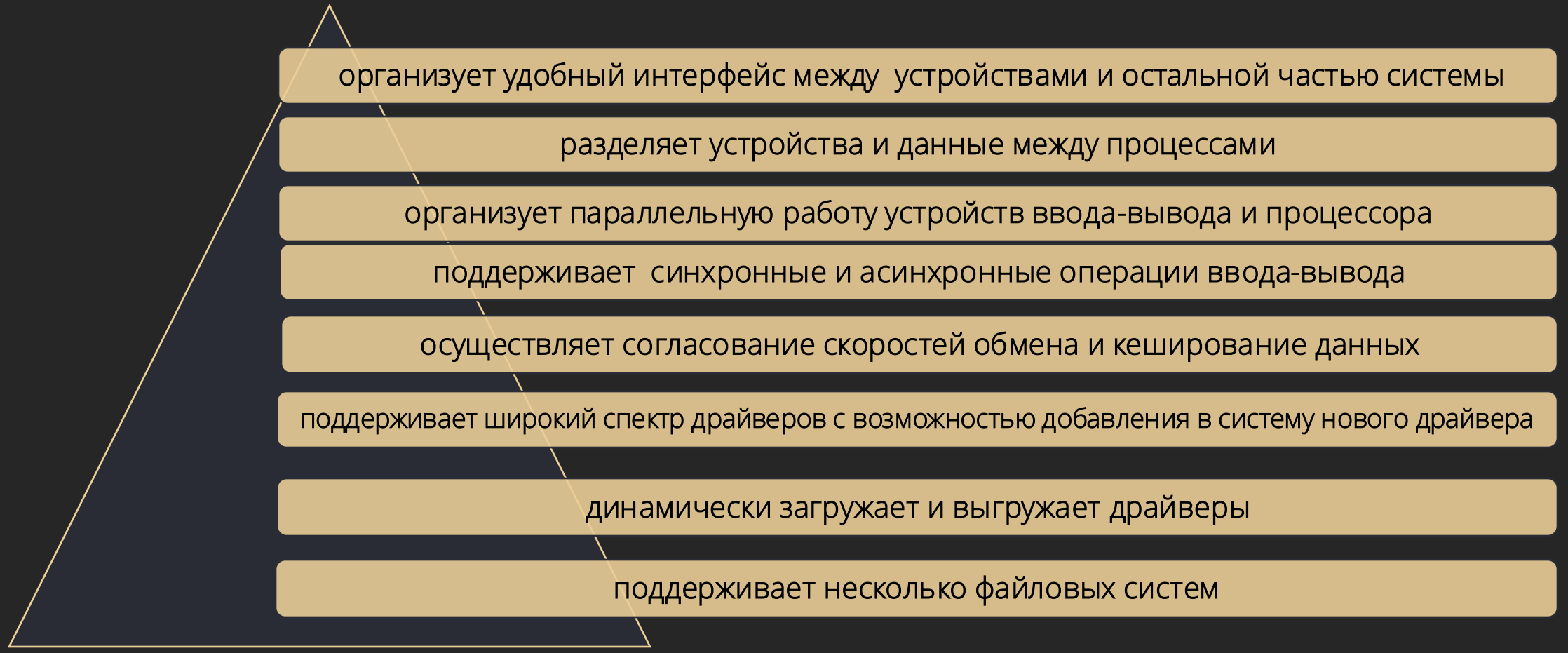


Подсистема управления памятью



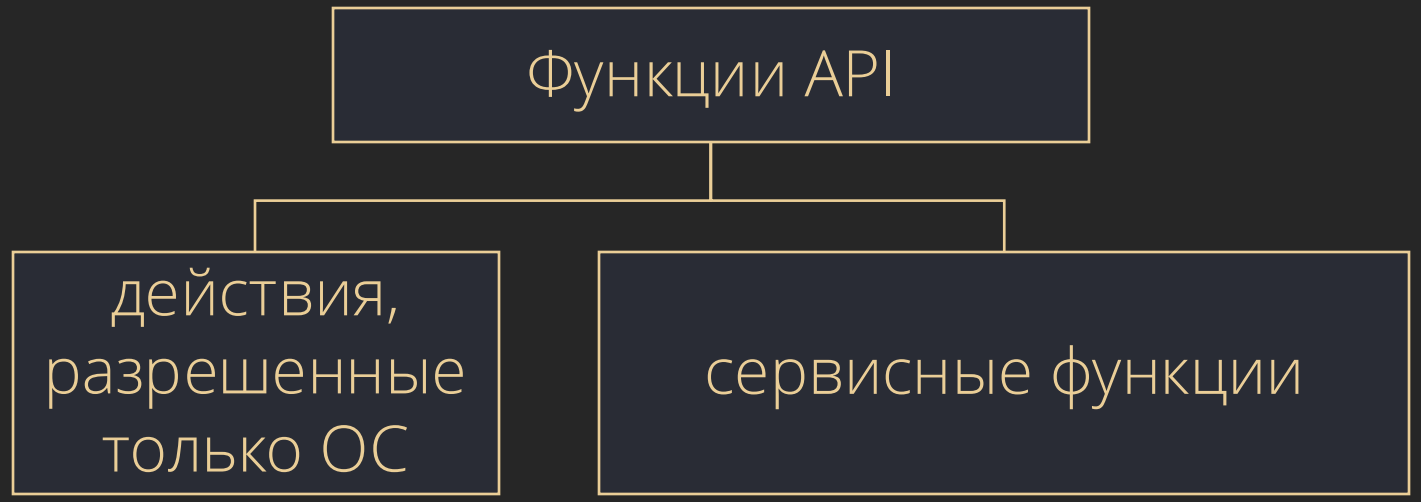
- отслеживает свободную и занятую память
- выделяет память процессам и освобождает память по завершении процессов
- загружает коды и данные процессов в отведенную память
- организует виртуальную память
- настраивает адреса программы на конкретную область физической памяти
- динамически распределяет память
- выполняет дефрагментацию памяти
- реализует защиту памяти

Подсистема управления файлами и внешними устройствами



Интерфейс прикладного программирования

Возможности ОС доступны прикладному программисту виде набора функций, которые составляют интерфейс прикладного программирования (Application Programming Interface, API).



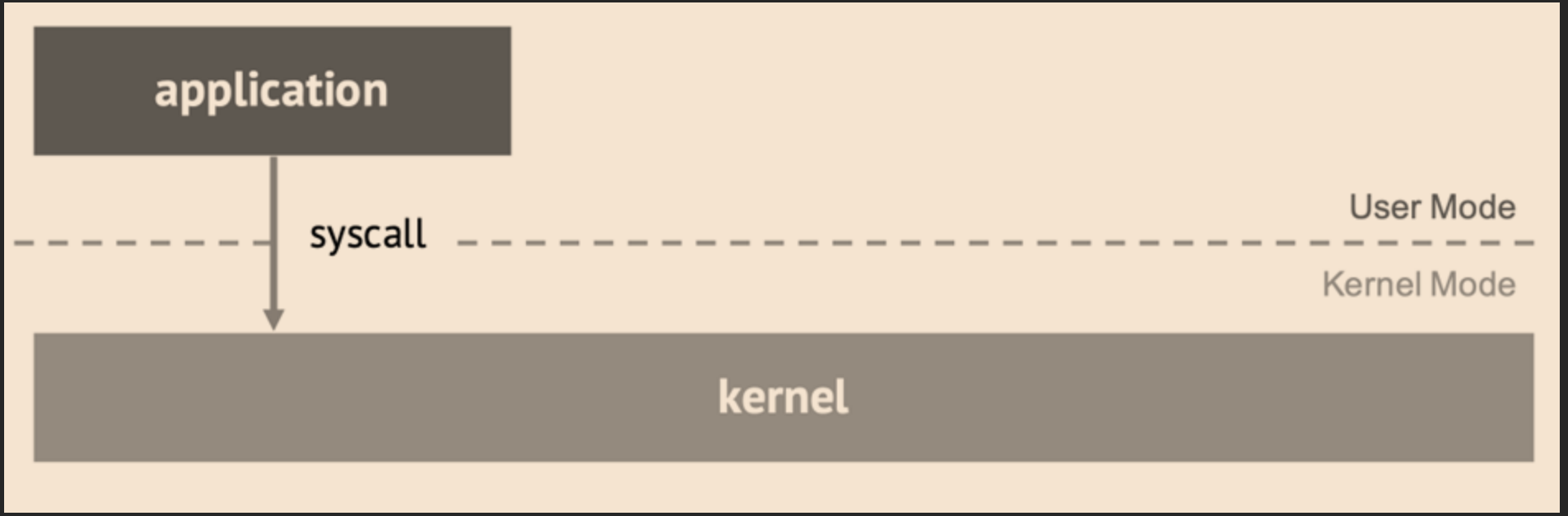
Системные вызовы



- ✓ Приложения выполняют обращения к ОС с помощью **системных вызовов**.

Системный вызов (SysCall)

Системный вызов - это обращение из кода в User Mode (User Space) к коду ядра:



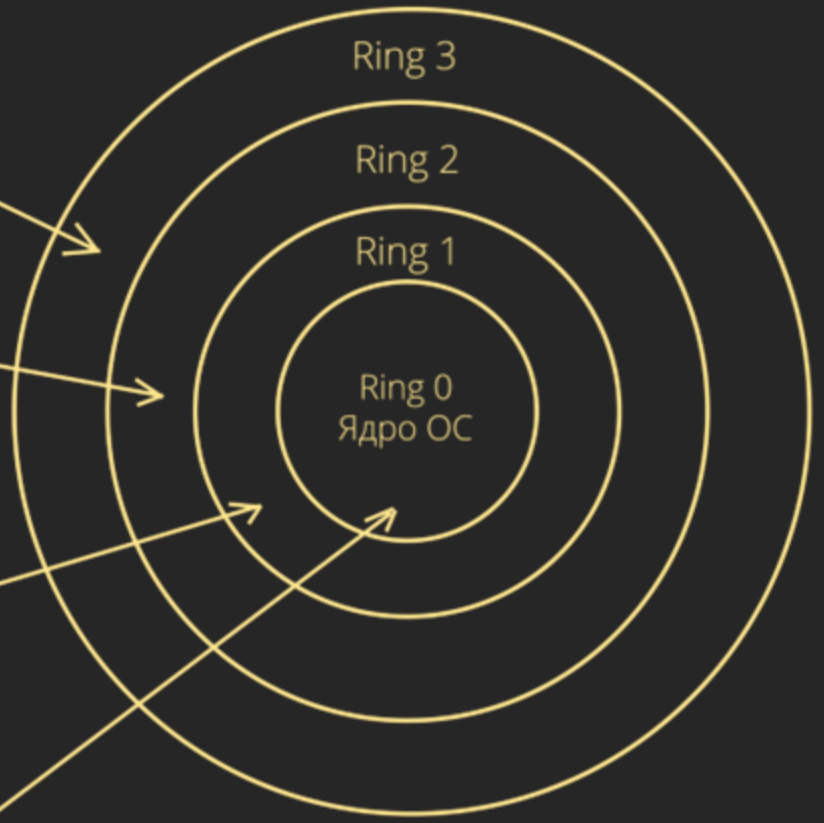
Системные вызовы реализуются с помощью **механизма программных прерываний**.

Пользовательский уровень - наименее привилегированный. Здесь работают прикладные программы

Уровень выполнения чуть более привилегированного кода, например программ с доступом к операциям ввода/вывода (использовался в OS/2)

Еще более привилегированный уровень, может быть использован для некоторых драйверов, на практике редко задействован

Режим супервизора - самый привилегированный уровень. Здесь работает ядро ОС



Системные вызовы

Реализация системных вызовов должна обеспечивать:

- переключение в привилегированный режим
- высокую скорость вызова процедур ОС
- по возможности единообразное обращение к системным вызовам для всех аппаратных платформ, для которых предназначена ОС
- возможность расширения набора системных вызовов
- контроль со стороны ОС использования системных вызовов



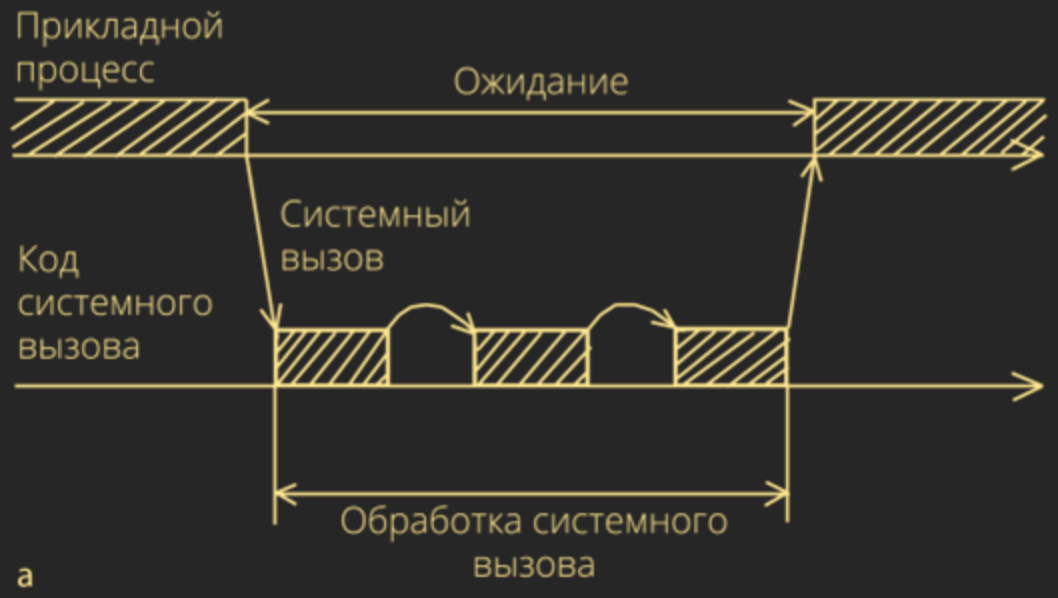
Системные вызовы реализуются с помощью механизма программных прерываний.

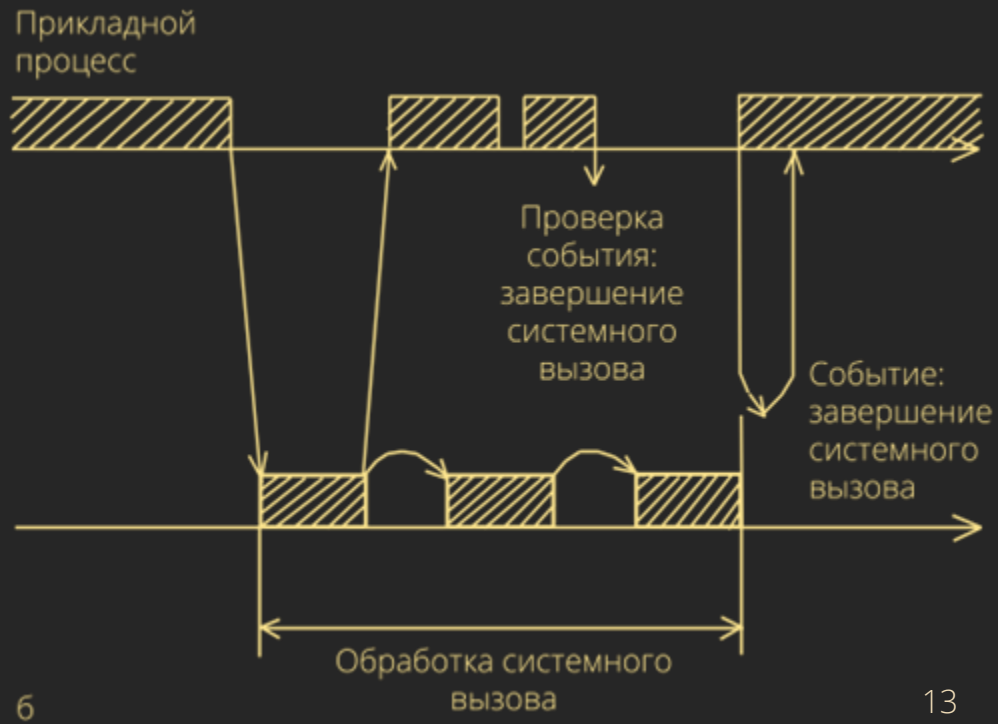
- ✓ Для разработчика приложений все особенности конкретной ОС представлены особенностями ее API. Поэтому разные ОС с одинаковым API кажутся им одной и той же ОС. Это упрощает стандартизацию ОС. Стандартом API UNIX является Posix.



Системные вызовы

- синхронные
- асинхронные





Схемы обработки системных вызовов

децентрализованная

централизованная





Приблизительное соответствие функций API в Windows и *nix

UNIX	Win32	Описание
fork	CreateProcess	Создает новый процесс
waitpid	WaitForSingleObject	Ожидает завершения процесса
execve	(нет)	CreateProcess=fork+execve
exit	ExitProcess	Завершает выполнение процесса
open	CreateFile	Создает файл или открывает существующий файл
close	CloseHandle	Закрывает файл
read	ReadFile	Читает данные из файла
write	WriteFile	Записывает данные в файл
lseek	SetFilePointer	Перемещает указатель файла
stat	GetFileAttrbutesEx	Получает различные атрибуты файла
mkdir	CreateDiectory	Создает новый каталог
rmdir	RemoveDirectory	Удаляет пустой каталог
link	(нет)	Win32 не поддерживает связи
unlink	DeleteFile	Удаляет существующий файл
mount	(нет)	Win32 не поддерживает подключение к файловой системе
umount	(нет)	Win32 не поддерживает подключение к файловой системе
chdir	SetCurrentDirectory	Изменяет рабочий каталог

Защита данных и администрирование



защита от сбоев и отказов аппаратуры
(реализуется путем резервирования)
защита от ошибок программного обеспечения
самовосстанавливающиеся файловые системы



защита от несанкционированного доступа
процедура логического входа, аутентификация, авторизация, администрирование, аудит

Критерии оценки безопасности операционных систем

1. **Анализ архитектуры ОС**

   Модель безопасности

оценка архитектуры ОС н наличие встроенных механизмов безопасности, таких как контроль доступа, шифрование и аутентификация.

   Контроль доступа

проверка, как ОС управляет правами доступа пользователей и приложений, а также насколько эффективно реализованы механизмы привилегий.

2. Тестирование на уязвимости

   Пенетрационное тестирование

Симуляция атак на систему для выявления уязвимостей, которые могут быть использованы злоумышленниками.

   Сканирование уязвимостей

использование автоматизированных инструментов для поиска уязвимостей в ОС и установленных приложениях.

3. Аудит конфигурации

Проверка настроек безопасности

Анализ конфигураций ОС на предмет соответствия передовым практикам безопасности, включая настройки брандмауэра, политики паролей и управление учетными записями.

Соответствие стандартам

Оценка ОС на соответствие стандартам безопасности, таким как ISO/IEC 27001, NIST, CIS Controls и другим.

4. Мониторинг и управление инцидентами

Журналирование и аудит

Проверка наличия и качества журналов событий, которые могут помочь в расследовании инцидентов.

Системы обнаружения вторжений (IDS)

Оценка эффективности систем, которые мониторят и анализируют сетевой трафик для выявления подозрительных действий.

5. Обновления и управление патчами

Политики обновления

Оценка процесса управления обновлениями и патчами для обеспечения актуальности системы и защиты от известных уязвимостей.

Скорость реагирования

Анализ времени, необходимого для внедрения критических обновлений безопасности.

6. Обучение пользователей

Повышение осведомленности

Оценка программ обучения пользователей по вопросам безопасности, таких как эффективное использование паролей, распознавание фишинга и соблюдение политик безопасности.

7. Тестирование на устойчивость к атакующим

Социальная инженерия

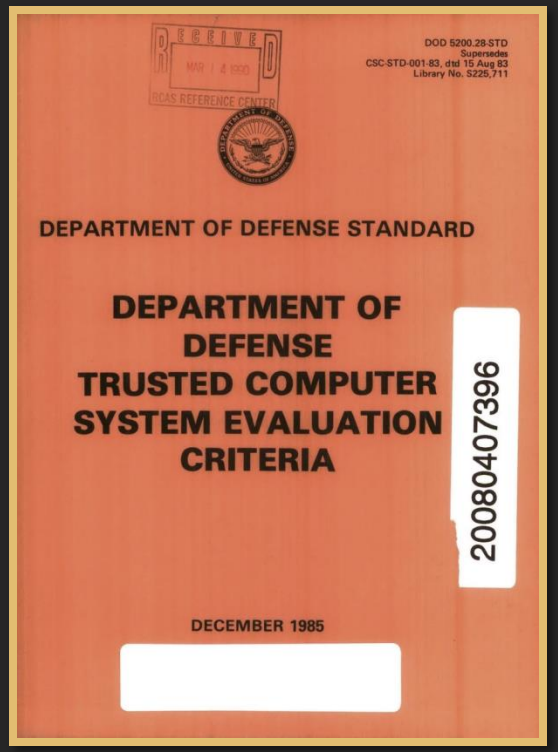
Оценка устойчивости системы к атакам, использующим манипуляции с пользователями для получения доступа к данным или ресурсам.

Стресс-тестирование

Проверка, как система справляется с ненормальными условиями, такими как перегрузка или попытки несанкционированного доступа.

Международные стандарты

«Оранжевая книга»



«Оранжевая книга» - стандарт МО США № 5200.28

Класс D: Minimal Protection (Минимальная защита) – к этому классу относятся системы, подобные DOS, так как защита в них практически отсутствует.

Класс C: Discretionary Protection (Избирательная защита) – большинство широко используемых операционных систем претендуют на соответствие защите по классу C2. Однако, есть разница между сертификацией по классу C2 в Национальном центре компьютерной безопасности (National Computer Security Center, NCSC) и просто соответствием уровню защищенности класса C2.

Класс C1: Discretionary Security Protection (Избирательная защита).

Класс C2: Controlled Access Protection (Управляемый доступ).

Класс B: Mandatory Security Protection (Обязательная защита) – система должна иметь математическое описание своей защиты и поддерживать защиту даже в отключенном состоянии.

Класс B1: Labeled Security Protection (Защита с применением меток безопасности)

Класс B2: Structured Protection (Структурированная защита)

Класс B3: Security Domains (Домены безопасности).

Класс A: Verified Protection (Верифицированная защита) – для проверки спецификаций такой системы применяются методы формальной верификации.

Класс A1: Verified Design (Верифицированная разработка)

Требования для класса безопасности C2:

- Владелец ресурса (например, файла) должен иметь возможность контролировать доступ к нему.
- ОС должна защищать объекты от их повторного использования другими процессами.
- Пользователи должны идентифицировать себя при помощи уникальных имен и паролей, пригодных для отслеживания деятельности пользователей.
- Администраторы должны иметь возможность аудита связанных с безопасностью событий, журналы событий должны быть защищены от несанкционированного доступа.
- ОС должна защищать саму себя от изменений.



Common Criteria (ISO/IEC 15408)

- Текущий стандарт оценки безопасности, используемый в США и во многих других странах, называется общими критериями (Common Criteria, CC).
- Common Criteria применяется к различным типам продуктов, включая операционные системы, сетевые устройства, базы данных, приложения и встроенные системы.

- Стандарт CC включает понятие **профиля защиты**, используемое для сбора требований безопасности в свободно определяемые и сопоставляемые наборы, и понятие **задания по безопасности** —Security Target, содержащего набор требований по безопасности, которые могут быть выдвинуты на основе профиля защиты.

1. **Структура**:
Common Criteria состоит из трех основных частей:

Part 1: Introduction and general model - вводная информация и общая модель.
Part 2: Security functional requirements - функциональные требования к безопасности, которые описывают, что система должна делать для обеспечения безопасности.
Part 3: Security assurance requirements** - требования к обеспечению безопасности, которые описывают, как производитель должен продемонстрировать, что система выполняет заявленные требования.

Common Criteria определяет **семь уровней оценки безопасности** (Evaluation Assurance Levels, EAL), от EAL1 (базовая оценка) до EAL7 (наивысший уровень оценки). Каждый уровень представляет собой набор требований как к функциональной безопасности, так и к обеспечению безопасности.

Сертификация по Common Criteria включает в себя несколько этапов:

- Определение целей оценки (Target of Evaluation, TOE)
- Подготовка документации, описывающей систему и ее безопасность
- Проведение оценки независимой лабораторией
- Выдача сертификата, если система соответствует требованиям

*Национальные стандарты

1. Федеральный закон "О защите информации"**
регулирует вопросы защиты информации, включая требования к безопасности информационных систем, в которых используются операционные системы.

2. Федеральный закон "О персональных данных"**
устанавливает требования к обработке и защите персональных данных, что также касается операционных систем, использующих такие данные.

3. Постановления правительства РФ
Постановление Правительства РФ № 1119** (2007 г.) "Об утверждении требований к защите информации в информационных системах" определяет требования к защите информации, обрабатываемой в информационных системах, включая операционные системы.

- Региональные и отраслевые стандарты*
- Методологии и руководства
- Документация производителя

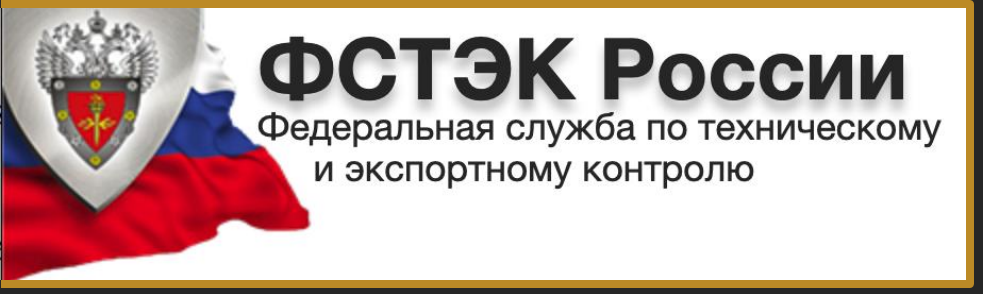
Многие производители ОС (например, Microsoft, Red Hat, Oracle) предоставляют собственные руководства и рекомендации по оценке и повышению безопасности своих продуктов.

Стандарты ФСТЭК

- *
  Федеральная служба по техническому и экспортному контролю (ФСТЭК) разрабатывает и публикует различные стандарты и методики, касающиеся безопасности информации.
  Например:
  - Стандарт "Система управления безопасностью информации" (СУБИ).
  - Методические рекомендации по оценке соответствия средств защиты информации.

  ГОСТы
  - ГОСТ Р 50922-96 Средства защиты информации. Общие требования" устанавливает общие требования к средствам защиты информации, включая операционные системы.
  - ГОСТ Р 52710-2007 "Информационная технология. Элементы безопасности. Общие требования к системам защиты информации" также охватывает аспекты безопасности ОС.

  Рекомендации по обеспечению безопасности
  - Рекомендации ФСТЭК и другие государственные органы могут издавать документы, касающиеся конкретных аспектов безопасности ОС, таких как антивирусная защита, управление доступом и др.



ИНФОРМАЦИОННОЕ СООБЩЕНИЕ ОБ УТВЕРЖДЕНИИ ТРЕБОВАНИЙ БЕЗОПАСНОСТИ ИНФОРМАЦИИ К ОПЕРАЦИОННЫМ СИСТЕМАМ от 18 октября 2016 г. N 240/24/4893

В соответствии с Требованиями выделяются следующие типы операционных систем:

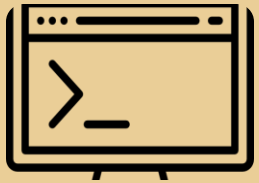
- операционная система общего назначения (тип "А") – операционная система, предназначенная для функционирования на средствах вычислительной техники общего назначения (автоматизированные рабочие места, серверы, смартфоны, планшеты, телефоны и иные);
- встраиваемая операционная система (тип "Б") – операционная система, встроенная (прошитая) в специализированные технические устройства, предназначенные для решения заранее определенного набора задач;
- операционная система реального времени (тип "В") – операционная система, предназначенная для обеспечения реагирования на события в рамках заданных временных ограничений при заданном уровне функциональности.

Для дифференциации требований к функциям безопасности операционных систем выделяются шесть классов защиты операционных систем. Самый низкий класс – шестой, самый высокий – первый.

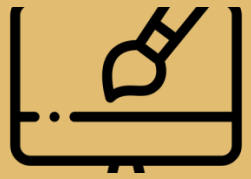
- Операционные системы, соответствующие 6 классу защиты, применяются в государственных информационных системах 3 и 4 классов защищенности* в автоматизированных системах управления производственными и технологическими процессами 3 класса защищенности** в информационных системах персональных данных при необходимости обеспечения 3 и 4 уровней защищенности персональных данных***.
- Операционные системы, соответствующие 5 классу защиты, применяются в государственных информационных системах 2 класса защищенности*, в автоматизированных системах управления производственными и технологическими процессами 2 класса защищенности**, в информационных системах персональных данных при необходимости обеспечения 2 уровня защищенности персональных данных***.
- Операционные системы, соответствующие 4 классу защиты, применяются в государственных информационных системах 1 класса защищенности*, в автоматизированных системах управления производственными и технологическими процессами 1 класса защищенности**, в информационных системах персональных данных при необходимости обеспечения 1 уровня защищенности персональных данных***, в информационных системах общего пользования II класса****.
- Операционные системы, соответствующие 1, 2 и 3 классам защиты, применяются в информационных (автоматизированных) системах, в которых обрабатывается информация, содержащая сведения, составляющие государственную тайну.

https://fstec.ru/normotvorcheskaya/informatsionnye-i-analiticheskie-materialy/1206-informatsionnoe-soobshchenie-fstek-rossii-ot-18-oktyabrya-2016-g-n-240-24-4893

Пользовательский интерфейс



алфавитно-цифровой (командный) интерфейс (CLI)



графический (WIMP: Window, Image, Menu, Pointer) интерфейс



голосовой (SILK: Speech, Image, Language, Knowledge) интерфейс



биометрическая технология